



T.C.
İSTANBUL TOPKAPI
ÜNİVERSİTESİ
MÜHENDİSLİK VE DOĞA
BİLİMLERİ FAKÜLTESİ
YAZILIM MÜHENDİSLİĞİ
BÖLÜMÜ

Üretken Yapay Zeka Sistemleri İçin Çok Katmanlı Akıllı Güvenlik Ağ Geçidi

Funda BOZBURUN

22040301045

Fidan AKYÜREK

22040301050

BİTİRME PROJESİ

İSTANBUL 2025

T.C.
İSTANBUL TOPKAPI
ÜNİVERSİTESİ
MÜHENDİSLİK VE DOĞA
BİLİMLERİ FAKÜLTESİ
YAZILIM MÜHENDİSLİĞİ
BÖLÜMÜ

Üretken Yapay Zeka Sistemleri İçin Çok Katmanlı Akıllı Güvenlik Ağ Geçidi

Funda BOZBURUN

22040301045

Fidan AKYÜREK

22040301050

Projenin Danışmanı : Dr. Öğr. Fatih Şahin
Jüri Üyesi :
Jüri Üyesi :

AKADEMİK DÜRÜSTLÜK BEYANI

Mezuniyet projesi olarak sunduğum “Üretken Yapay Zeka Sistemleri İçin Çok Katmanlı Akıllı Güvenlik Ağ Geçidi” başlıklı çalışmanın, bilimsel ahlak ve geleneklere uygun olarak tarafımdan yazıldığını, yararlandığım eserlerin tamamının kaynaklarda gösterildiğini ve çalışmam içerisinde kullandıkları her yerde atıf yapıldığını belirtir ve onurumuzla doğrularız.

Tarih

Öğrenci Adı Soyadı

Funda BOZBURUN
Fidan AKYÜREK

TEŞEKKÜR

Çalışmalarımız süresince bilimsel katkıları ile bizi aydınlatan, farklı bakış açıları ile yol gösteren, yakın ilgi ve yardımları ile beni motive eden ve bu günlere gelmemizde en büyük katkı sahibi olan Sayın Sajjad Nematzadeh'e teşekkürü bir borç biliriz.

Deneysel çalışmalarımız sırasında karşılaştığımız zorlukları aşmamızda yardımlarından dolayı Fatih Şahin'e teşekkür ederiz.

Ayrıca, çalışmalarımız süresince sabır göstererek bizi daima destekleyen değerli ailelerimize ve arkadaşlarımıza en içten teşekkürlerimizi sunarız.

Tarih

Öğrenci Adı

Funda BOZBURUN

Fidan AKYÜREK

ÖZET

Büyük Dil Modellerinin (LLM) ve Üretken Yapay Zeka (GenAI) sistemlerinin günlük kullanıma ve kurumsal iş süreçlerine hızla entegre edilmesi ile zaman kaybı engellenmiş, üretkenlik arttırılmıştır. Ancak beraberinde yeni riskleri de doğurmuştur. “İstem Enjeksiyonu” (Prompt Injection) ve “Hassas Veri Sızıntısı” (Data Leakage) gibi siber güvenlik risklerine de neden olmuştur. Geleneksel yöntemlerin, doğal dil üzerinde gerçekleşen anlamsal ve manipölasyon barındıran siber saldırıları engellemekte yetersiz kalması büyük güvenlik açığı oluşturmaktadır. Bu çalışmanın temel amacı; kurum içi kullanıcılar ile yapay zeka modelleri arasında konumlanan “Çok Katmanlı Güvenlik Ağ Geçidi” geliştirmektir. Gizli verilerin dışarı sızmasını engelleyen (DLP) ve saldırı girişimlerini gerçek zamanlı durduran bir sistem hedeflenmektedir.

Çalışmada yöntem olarak, üç aşamalı çok katmanlı hibrit mimari tasarlanacaktır. Birinci katmanda kural tabanlı filtre (Regex) sayesinde, milisaniyeler içerisinde bilinen tehditler engellenir ve kişisel veriler (PII) maskelenerek veri sızıntısı önlenir. İkinci katmanda DeBERT tabanlı yapay zeka modeli ile anlamsal saldırı analizi yapılır. Yetersiz kaldığı durumlarda devreye üçüncü katman girer. Üçüncü katmanda ise karmaşık mantıksal manipölasyonlar için bir “LLM Yargıç” mekanizması kullanılır.

Yapılan çalışmalar ve araştırmalar doğrultusunda, geliştirilmesi planan sistemin basit düzeydeki saldırı girişimlerini henüz yapay zeka katmanına ulaşmadan engellemesi öngörülmektedir. Ayrıca kademeli eleme stratejisi sayesinde gereksiz isteklerin bir üst katmana iletilmesi engellenir. Böylece maliyetten ve enerjiden tasarruf edilmesi sağlanarak “Yeşil Bilişim” (Green Computing) hedefine ulaşılır. Çalışmanın en önemli hedef sonucu; ticari “kapalı kutu” yaklaşımlarının aksine verilerin kurum dışına çıkmadığı ve KVKK uyumluluğu sağlayan, yerel bir güvenlik mimarisinin uygulanabilirliğini göstermektir.

Anahtar Kelimeler: Üretken Yapay Zeka Güvenliği, İstem Enjeksiyonu (Prompt Injection), Veri Kaybı Önleme (DLP), LLM Güvenlik Duvarı, Doğal Dil İşleme.

ABSTRACT

The rapid integration of Large Language Models (LLMs) and Generative Artificial Intelligence (GenAI) systems into daily use and corporate workflows has prevented time loss and increased productivity. However, this has also given rise to new risks. It has also led to cybersecurity risks such as “Prompt Injection” and “Data Leakage.” The inadequacy of traditional methods in preventing cyberattacks involving semantic and manipulative attacks on natural language creates a significant security vulnerability. The main objective of this study is to develop a “Multi-Layer Security Gateway” positioned between internal users and artificial intelligence models. The goal is to create a system that prevents confidential data from leaking (DLP) and stops attack attempts in real time.

As a method, a three-stage, multi-layered hybrid architecture will be designed in this study. In the first stage, rule-based filtering (Regex) blocks known threats within milliseconds and masks personal information (PII) to prevent data leakage. In the second layer, semantic attack analysis is performed using a DeBERT-based artificial intelligence model. If this proves insufficient, the third layer is activated. The third layer uses an “LLM Judge” mechanism for complex logical manipulations.

Based on the studies and research conducted, the planned system is expected to block simple attack attempts before they reach the artificial intelligence layer. Furthermore, the stepwise elimination strategy prevents unnecessary requests from being forwarded to the upper layer. This saves money and energy, achieving the goal of “Green Computing.” The most important outcome of the study is to demonstrate the feasibility of a local security architecture that ensures KVKK compliance and prevents data from leaving the organization, unlike commercial “black box” approaches.

Keywords: Generative AI Security, Prompt Injection, Data Loss Prevention (DLP), LLM Firewall, Natural Language Processing.

İÇİNDEKİLER

AKADEMİK DÜRÜSTLÜK BEYANI	i
TEŞEKKÜR	ii
ÖZET	iii
ABSTRACT	iv
İÇİNDEKİLER	v
ŞEKİLLER DİZİNİ	vi
ÇİZELGELER DİZİNİ	vii
KISALTMALAR	viii
1. GİRİŞ	1
1.1. Problem Tanımı	2
1.1.1. Veri Sızıntısı (Data Leakage)	2
1.1.2. Prompt Injection Ve Jailbreak	3
1.2. Projenin Amacı Ve Kapsamı	4
2. KAYNAK ARAŞTIRMASI	5
2.1. Büyük Dil Modellerinde Güvenlik Paradigması	5
2.2. Literatürdeki Saldırı Vektörleri Ve Analizler	6
2.2.1. Rol Yapma(Role -Playing) Ve Sosyal Mühendislik	6
2.2.2. Evrensel Çekişmeli Saldırıları (Universal Adversarial Attacks)	6
2.3. Mevcut Savunma Yaklaşımı Ve Sınırlılıkları	7
2.4. Endüstriyel Ve Ticari Güvenlik Çözümleri	9
2.4.1. Lakera Guard	9
2.4.2. Nvidia Nemo Guardrails	9
2.4.3. Lasso Security	9
2.4.4. Cloudflare For AI	9
3. MATERYAL VE YÖNTEM	10
3.1. Veri Hazırlama	10
3.1.1. Veri Toplama	10
3.1.2. Veri Temizleme Ve Ön İşleme	11
3.2. GenAI Güvenlik Ağ Geçidi Mimarisi	11
3.2.1 Sistem Tasarımı	11
3.2.2. Algoritma Ve Kodlama Yöntemleri	13
4. SONUÇLAR	14
4.1. Hedeflenen Performans Metrikleri	14
4.2. Katman Bazlı Beklenen Davranış Analizi	15
4.3. Öngörülen Test Senaryoları Ve Çıktılar	16
4.4. Projenin Nihai Çıktıları	17

4.5. Gereksinim Analizi.....	17
4.6. Sistem Tasarımı Ve Modelleme (Diyagramlar)	20
4.6.1. Use Case Diyagramı	20
4.6.2. Class Diyagramı	21
4.6.3. Erd(Varlık-İlişki Diyagramı).....	21
4.6.4. DEPLOYMENT DİYAGRAMI.....	23
4.6.5. Sequence Diyagramı.....	24
4.6.6. İş Paketleri Zamanlama Tablosu Ve Çıktıları	25
4.7. UX Tasarımları.....	27
4.7.1. SOC Dashboard (Ana Panel).....	27
4.7.2. LOG ANALİZ VE DETAY SAYFASI	27
4.7.3. Güvenlik Kuralları Ve Ayarlar	28
5. TARTIŞMA	28
5.1. Genel Değerlendirme Ve Beklenen Başarı Analizi.....	28
5.2. Literatür Ve Mevcut Ticari Çözümlerle Karşılaştırma.....	29
5.3. Projenin Gerçekçi Kısıtları Ve Yönetim Stratejileri	30
5.3.1. Zaman Ve Bütçe Kısıtları	30
5.3.2. Donanım Ve Teknik Kısıtlar	30
5.3.3 Yasal Ve Etik Kısıtlar(Veri Mahremiyeti)	30
5.4. Sürdürülebilir Kalkınma Amaçları (SKA) Ve Çevresel Etki	31
5.4.1 Sanayi Yenilikçilik Ve Altyapı (Ska 9).....	31
5.4.2. Barış Adalet Ve Güçlü Kurumlar (Ska 16)	31
5.4.3. Yeşil Bilim Ve Enerji Verimliliği	31
5.5. Olası Hata Kaynakları Ve Sınırlılıkları	32
5.6. Gelecek Çalışmalar Ve İyileştirme Önerileri	32
6. EKLER.....	33
6.1. EK-1: Kullanılan Veri Setlerinden Örneklemeler	33
6.2. EK-2 Sistem Mimarisi Kritik Kod Blokları	34
6.3. EK-3 API Uç Noktaları Ve Entegrasyon Dökümantasyonu	35
6.4. EK-4: Proje Zaman Çizelgesi Ve İş Paketi Dağılımı	37
7. KAYNAKLAR	38
8. ÖZGEÇMİŞ	39

ŞEKİLLER DİZİNİ

Şekil 1.Çok Katmanlı Akıllı Güvenlik Ağ Geçidi Mimari Tasarımı.....	12
Şekil 2.Use Case Diyagramı	20
Şekil 3. Class Diyagramları	21
Şekil 4.ER Diyagramı	22
Şekil 5.Deployment Diyagramı	23
Şekil 6. Sequence Diyagramı	24
Şekil 7.Yönetici Paneli (SOC Dashboard) Tasarımı.....	27
Şekil 8.Saldırı Detay ve İnceleme Ekranı.....	27
Şekil 9.Güvenlik Konfigürasyon Ekranı.....	28

ÇİZELGELER DİZİNİ

Tablo 1. OWAPS Top 10 LLM Uygulamaları İçin Kritik Güvenlik Riskleri ve Proje Kapsamı.	3
Tablo 2.Literatürdeki Mevcut Çalışmalar ile Önerilen Sistemin Karşılaştırması.....	8
Tablo 3.Sistemin Hedeflenen Performans ve Başarı Kriterleri.....	15
Tablo 4.Fonksiyonel Gereksinimler Listesi.....	18
Tablo 5.Fonksiyonel Olmayan Gereksinimler Listesi	19
Tablo 6.Sistem ve donanım gereksinimleri	19
Tablo 7.Proje İş Paketleri ve Zaman Planlaması	25
Tablo 8.Proje Çıktıları ve Başarı Ölçütleri	26
Tablo 9. Önerilen Sistemin Literatür ve Endüstriyel Çözümlerle Karşılaştırmalı Analizi	29
Tablo 10.Test Kümesi Örnek Veri Tablosu.....	33
Tablo 11.API Uç Noktaları.....	36

KISALTMALAR

CNN: Convolutional Neural Network

GA: Genetic Algorithm

ML: Machine Learning (Makine Öğrenmesi)

PII: Personally Identifiable Information (Kişisel Tanımlanabilir Bilgiler)

AI : Artificial Intelligence (Yapay Zeka)

API : Application Programming Interface (Uygulama Programlama Arayüzü)

BERT : Bidirectional Encoder Representations from Transformers

CPU : Central Processing Unit (Merkezi İşlem Birimi)

DAN : Do Anything Now

DeBERTa : Decoding-enhanced BERT with Disentangled Attention

DLP : Data Loss Prevention (Veri Kaybı Önleme)

ERD : Entity Relationship Diagram (Varlık-İlişki Diyagramı)

FPR : False Positive Rate (Hatalı Pozitif Oranı)

GCG : Greedy Coordinate Gradient

GDPR : General Data Protection Regulation (Genel Veri Koruma Tüzüğü)

GenAI : Generative Artificial Intelligence (Üretken Yapay Zeka)

GPU : Graphics Processing Unit (Grafik İşlem Birimi)

HTTP : Hypertext Transfer Protocol

KVKK : Kişisel Verilerin Korunması Kanunu

LLM : Large Language Model (Büyük Dil Modeli)

ML : Machine Learning (Makine Öğrenmesi)

OWASP : Open Web Application Security Project

PII : Personally Identifiable Information (Kişisel Tanımlanabilir Bilgiler)

REST : Representational State Transfer

RLHF : Reinforcement Learning from Human Feedback (İnsan Geri Bildirimli Pekiştirmeli Öğrenme)

SKA : Sürdürülebilir Kalkınma Amaçları

SOC : Security Operations Center (Güvenlik Operasyon Merkezi)

SQL : Structured Query Language (Yapılandırılmış Sorgu Dili)

TPR : True Positive Rate (Doğru Pozitif Oranı / Saldırı Tespit Oranı)

UML : Unified Modeling Language (Birleşik Modelleme Dili)

WAF : Web Application Firewall (Web Uygulaması Güvenlik Duvarı)

WP : Work Package (İş Paketi) **XSS** : Cross-Site Scripting (Siteler Arası Komut Dosyası Çalıştırma)

1. GİRİŞ

İnsanlık tarihi boyunca teknolojik gelişmeler, devletlerin üretim ve iş biçimlerini kökten değiştirmiştir. Sanayi devrimi kas gücünü makine gücüne dönüştürerek bazı şeyleri aşmış olup, günümüzde yaşanan dijital devrim, zihinsel süreçleri algoritmik hesaplamalara bırakmaktadır. Endüstri 4.0 olarak adlandırılan bu dönüşüm merkezinde ise Yapay Zeka (Artificial Intelligence / AI) yer alır. En temel tanımıyla yapay zeka; öğrenme, problem çözme, karar verme ve örüntü tanıma gibi insan zekasına özgü fonksiyonların makineler ile taklit edilmesidir. [1]

Yapay zeka teorik olarak 1950' lere dayanmakla birlikte, son on yılda Grafik İşleme Birimlerinin (GPU) işlem gücündeki artış ve büyük veri setlerinin erişilebilir olması ile birlikte, Makine Öğrenmesi (Machine Learning/ ML) ve bir alt dalı olan Derin Öğrenme (Deep Learning) alanlarında devrim yaşanmıştır. Makine öğrenmesi; bilgisayarların açıkça, tamamen programlanmadan verilerden öğrenmesini sağlayan algoritmalar bütünüdür. Ancak bu alandaki kırılma noktası, 2017 yılında Vaswani ve arkadaşları tarafından yayınlanan "Attention Is All You Need" makalesiyle çıkan "Transformer" mimarisi olmuştur.[2] Bu mimari ardışık veri işleme zorunluluğunu ortadan kaldırarak, ChatGPT, Gemini, Ve Claude gibi Yapay Zeka sistemlerinin temelini oluşturmuştur.

2022 Yılı'nın sonlarında OpenAI tarafından geliştirilen ChatGPT' nin halka açılması, teknoloji tarafından bir milat kabul edilmektedir. Sadece 2 ay içinde 100 milyon kullanıcıya ulaşarak internet tarihinin en hızlı büyüyen uygulaması olan sistem, laboratuvarlardan çıkıp son kullanıcının cebine de dahil olmuştur. Ardından Google'ın Gemini (eski adıyla Bard) ve Anthropic'in Claude modelleri bu yarışa katılmıştır. Bu sistemler "Büyük Dil Modelleri"(Large Language Models / LLM) ile adlandırılır ve trilyonlarca parametre ile eğitilerek insan dilini anlama, yorumlama ve üretme yeteneğine kavuşmuşlardır. [3]

Bu teknolojiler gündelik hayatımızla birlikte iş dünyasına da sağladığı kolaylıklar oldukça fazladır. Yazılım geliştiriciler için kod yazma, pazarlamacılar için üretme-satış gibi konularda ve analistler içinde veri özetleme süreleri günler süreceksen saniyelere kadar düşmüştür. Erişilebilirlikleri çok kolay olduklarından dolayı nerede bir zorluk olduğunda bu yazılım işlerinden bilgisi olmayanlara dahi kolaylıkla fayda sağlayıp bilgilendirme yapmıştır. Otomasyon konularında ise müşteri hizmetlerinin ve ofis de

yapılacak rutin işlemlerin, yapay zeka asistanları tarafından 7/24 ve otonom olarak kullanılmaya başlanmıştır. Ancak, her teknolojik yükselişte beraberinde getirdiği yeni güvenlik zafiyetleri ve riskleri de ortaya çıkmaktadır. GenAI sistemlerinin kurumsal ağlara kontrolsüz entegrasyonu, siber güvenlik dünyasında sınırları belli olmayacak derecede belirsiz sıkıntılı cepheler açmıştır.

1.1. Problem Tanımı

Geleneksel siber güvenlik yaklaşımları; ağ trafiğini IP adresleri, portlar ve protokoller üzerinden denetleyen kurallara (Firewall/ WAF) dayalıdır. Ancak büyük dil modelleri ile yapılan iletişim, tamamen “doğal dil” üzerinden gerçekleşmektedir ve olasılıksaldır. Geleneksel güvenlik duvarları, bir metnin ‘sözdizimini’ (syntax) görebilse de, ‘anlamını ve niyetini’ kavrayamaz. Bu durum, “Gölge YZ” (Shadow AI) kullanımından kaynaklanan iki temel tehditle karşılaşmaktadır.

1.1.1. Veri Sızıntısı (Data Leakage)

Çalışanlar, işleri hızlandırmak için şirket dahilinde olan önemli bilgileri (PII- Kişisel Tanımlanabilir Bilgiler, Kaynak Kodlar, Finansal Raporlar) iyi niyetli bir yaklaşımla halka açık olan yapay zeka modellerine atıp onlarla alakalı işlemler yapabilmektedirler.

Bu riskin sonucunda oluşan ve kötü sonuçlar doğuran olay örneği, 2023 yılında teknoloji devi SAMSUNG’da yaşanmıştır. Şirketteki mühendisler, üretimdeki verimliliği artırmak ve hatalı kodları düzeltmek amacıyla çok gizli çip kaynak kodlarını ve toplantı tutanaklarını ChatGPT’ ye yüklemişlerdir. Bu veriler, modelin öğrenme havuzuna girdiğinde şirketin en büyük ticari sırları istenmeden de olsa halka açık bir platformun veritabanına sızdırılmıştır.[4] Bu olay, verilerin model eğitimi için kullanılması durumunda, rakip firmaların sorgularında bu gizli bilgilerin ortaya çıkma riskini meydana getirmiştir.

1.1.2. Prompt Injection Ve Jailbreak

Siber saldırganlar, yapay zeka modellerinin güvenliklerini aşmak için “Prompt Injection (İstem Enjeksiyonu)” adı verilen bir teknik geliştirmiştir. Bu saldırı türünde, saldırgan modele normal bir komut veriyormuş gibi göstererek, arka planda modelin etik kuralların devre dışı bırakmasını sağlar.

Bu durumun ticari açıdan itibar kaybetmesine yol açan güncel bir örneği, ABD’ de bir ‘Chevrolet bayisinin’ web sitesine entegre ettiği ChatGPT tabanlı müşteri temsilcisi botunda yaşanmıştır. Kullanıcılar botu manipüle ederek (Prompt injection) ona her teklifi kabul etmesini söylemiş ve 1 dolara lüks bir araç satın alma onayını almışlardır.[5] Benzer şekilde, “DAN” (Do Anything Now) gibi jailbreak teknikleri ile modele bomba yapım tarifi veya oltalama (phishing) e-posta taslağı hazırlatmışlardır.

OWASP(Open Web Application Security Project), bu risklerin ciddiyeti nedeniyle “OWAPS TOP 10 FOR LLM” listesini yayınlayarak, “ Prompt injection” ve “Hassas veri ifşası” nı en önemli riskler olarak tanımlamıştır.[6] Proje kapsamında ele alınan ve sistemin mimarisiyle doğrudan hedeflenen kritik riskler Tablo 1 ‘ de özetlenmiştir.

Tablo 1. OWAPS Top 10 LLM Uygulamaları İçin Kritik Güvenlik Riskleri ve Proje Kapsamı.

Risk Kodu	Risk Adı	Açıklama	Projedeki Çözümü
LLM01	Prompt Injection	Saldırganın modeli manipüle ederek güvenlik sınırlarını aşması.	DeBERTa tabanlı analiz (Katman 2)
LLM02	Insecure Output Handling	Modelin ürettiği zararlı çıktıların (XSS vb.) filtrelenmemesi.	Çıktı denetimi ve LLM Yargıç (Katman 3)
LLM06	Sensitive Information Disclosure	Modelin eğitim verisindeki hassas bilgileri ifşa etmesi.	PII Makeleme Modülü (Katman 1)

LLM10	Model Denial Of Service	Modele aşırı yük bindirerek kaynak tüketimi yapılması.	Kural Tabanlı ön eleme ile gereksiz isteği engelleme (Green AI)
-------	-------------------------	--	---

Tablo 1’ de detaylandırılan bu tehditlere karşı bu boşlukları doldurmak ve böyle hataları önlemek amaçlı piyasada “ Lasso Security, Lakera Guard ve Cloudflare For AI” gibi çözüm olan sistemler geliştirilmiştir. Ancak bu çözümlerin genellikle bazı kısıtları vardır. Bunlardan bazılarını açıklayacak olursak:

Her biri birer “Kapalı Kutu (Black Box)” dur. Yani güvenlik kararlarını nasıl aldığını, hangi algoritmaları kullandığı hakkındaki bilgiler şeffaf değildir. Başka bir sorun olan “Veri Egemenliği” konusundan bahsetmek gereklidir. Bu kısımda, verilerimizin analizi için yurt dışındaki sunuculara gitmesi, KVKK ve GDPR uyumluluğunu zorlaştırmaktadır. Maliyet bakımından da sorunlar yaşanmaktadır. Özellikle KOBİ’ler ve akademik çalışmalar için fiyatı yüksek derecede olan lisans ücretlerine sahiptirler ve kuruma özel modellerin entegrasyonuna da izin verilmemektedir. Literatürdeki yapılan akademik çalışmalarda genellikle sadece “Saldırı Tespiti” (Detection) üzerine odaklanılmış, saldırıyı engelleyip aynı zamanda da özel verileri maskeleyen bir “Ağ Geçidi”(Gateway) mimarisi üzerinde yeterince çalışılmamıştır.

1.2. Projenin Amacı Ve Kapsamı

Bu bitirme projesinin temel amacı detaylıca açıklandığı üzere; kurumdaki çalışanların yapay zeka modelleri (OpenAI, Google Gemini vb.) arasında konumlanan, hassas verilerin sızıntısını engelleyen ve saldırıları engelleyen akıllı bir “Güvenlik Ağ Geçidi”(Security Gateway) geliştirmektir.

Projemizi yapma amaçlarımızdan temel olarak bahsetmek gerekirse:

“Görünürlük” sağlamak istiyoruz. Yani kurum içinden yapay zekaya giden tüm prompt, cevap ve kod gibi bilgi trafiğini kayıt altına alarak izlenebilirliğini sağlamak. Diğer amaçlarımızdan da bahsedecek olursak, Hassas verileri yani kredi kartı, T.C. kimlik numarası, önemli kod blokları gibi bilgileri yapay zekaya gitmeden önce yakalayıp maskeleyen işlemi (DLP-Data Loss Prevention) gerçekleştirmek. Kötü niyetli

kullanıcıların “Prompt Injection” tekniklerini kullanarak sistemi kandırmasını engellemek ve geçersiz, zararlı istekleri daha sunucuya ulaşmadan engelleyerek, yüksek enerji tüketen LLM modellerinin gereksiz yere çalıştırılmasını önlemek ve karbon ayak izini düşürerek “Yeşil Bilime” de katkıda bulunmak amaçlanmaktadır.

Projede, literatürdeki benzerlerinden farklı olarak “Çok Katmanlı (Multi Layer)” savunma stratejisi izlenecektir. İlk katmanda “Kural Tabanlı (Regex)” filtreler ile hızlı eleme yapılırken, ikinci katmanda “Makine Öğrenmesi (DeBERTa)” modelleri ile cümle anlam analizi yapılır, son katmanda ise bir “LLM Yargıç (LLM Judge)” mekanizması ile karmaşık olan mantıksal ve anlamsal saldırılar çözümlenecektir. Bu hibrit yapı, güvenli olup düşük gecikme süresi (low latency) sunmayı hedeflemektedir.

2.KAYNAK ARAŞTIRMASI

Bu bölümde, mevcut proje konusu dahilinde geniş çaplı araştırmalar yapılmış, daha önce gerçekleştirilen ulusal ve uluslararası çalışmalar detaylıca incelenmiştir. Literatürdeki mevcut yaklaşımlar özetlenmiştir. Yapılan çalışmalar sırasında kullanılan yöntem ve teknikler, elde edilen sonuçların güçlü ve zayıf yönleri eleştirisel bir bakış açısıyla değerlendirilerek söz konusu hayata geçirilmesi hedeflenen projenin hangi ihtiyacı karşılayacağı açıklanmaktadır. Böylece projenin literatürdeki özgün yeri, bilimsel temelleri ve alana sağlayacağı katkıları belirtilmiştir.

Büyük dil modelleri (Large Language Models – LLM) güvenliği 2022 yılı sonunda ChatCPT’nin halka açılması ile birlikte çok daha fazla önem kazanan ve hızla büyüyen henüz çok yeni ve dinamik bir araştırma sahası haline gelmiştir. Literatür taraması sonucunda güncel çalışmaların “Saldırı Metodolojileri (Offensive Security)” ve “Savunma Mekanizmaları (Defensive Security)” olmak üzere iki ana başlık üzerinde yoğunlaştığı görülmüştür.

2.1. Büyük Dil Modellerinde Güvenlik Paradigması

Geleneksel siber güvenlik bakış açısı önceden tanımlanmış kesin kurallar bütününe (Örn: SQL Injection) dayanırken, Üretken Yapay Zeka (GenAI) sistemleri olasılıksal (probalistic) olasılıksal anlayışa dayanır. Doğal dil tabanlı çalıştığı için bu sayede güvenlik paradigmasının değişikliğe uğramasına neden olmuştur. Vaswani ve arkadaşlarının (2017) ortaya koyduğu Transformer mimarisi göz önünde bulundurulduğunda, bu

mimarının metni işlerken “kullanıcı verisi” ile “sistem talimatları”nı aynı bağlamda (context) değerlendirdiği ve bu durumun modelin manipülasyona açık hale gelmesine neden olduğu görülmektedir. Bu teknik boşluk, literatürde “İstem Enjeksiyonu” (Prompt Injection) olarak adlandırılan saldırı türünün temelini oluşturmaktadır.

2.2. Literatürdeki Saldırı Vektörleri Ve Analizler

Saldırganların sistemi nasıl manipüle edip istekleri doğrultusunda kullandıklarına dair yapılan araştırmalar ve akademik çalışmalar, projemizde savunma sistemimizde yol gösterici nitelikte olmuştur. Literatürde öne çıkan saldırı çeşitleri şunlardır:

2.2.1. Rol Yapma(Role -Playing) Ve Sosyal Mühendislik

Lui ve arkadaşları 2023 yılında “Jailbreaking ChatCPT via Prompt Engineering” adlı kapsamlı çalışmalarında ticari modelleri incelemişlerdir. Bu modellerin güvenlik duvarlarını aşmak için kullanılan yöntem ve teknikleri analiz etmişlerdir. Çalışmada, “DAN” (Do Anything Now) ve “Developer Mode” gibi kurgusal senaryoların kullanılması durumunda, modellerin hizalama (alignment) eğitiminin %80’e varan oranlarda devre dışı bırakılabildiği ampirik verilerle kanıtlanmıştır. Bu çalışmada yalnızca anahtar kelime filtrelerinin yeterli olmadığı tespit edilmiştir. Modern ve karmaşık saldırıları durdurmak için anlamsal analiz yapan ve aradaki bağlamı algılayabilen sistem gerekliliği görülmüştür.

2.2.2. Evrensel Çekişmeli Saldırıları (Universal Adversarial Attacks)

Zou ve arkadaşları 2023 yılında “Universal and Transferable Adversarial Attacks on Aligned Language Models” çalışmalarında, insan gözüyle anlamsız görünen ancak yapay zeka modellerinin matematiksel vektör uzayında “kırılma” yaratan özel karakter dizileri (suffix) geliştirmişlerdir. Bu yaratıcı saldırı türüne GCG (Greedy Coordinate Gradient) denir. GCG, yapay zeka güvenliğinde “ikna etme sanatından” “matematik mühendisliğine” geçişi temsil eder. Saldırıların doğal dille değil, matematiksel optimizasyonla da yapılabileceği açıktır.

2.3. Mevcut Savunma Yaklaşımı Ve Sınırlılıkları

Literatürde bu saldırılara karşı geliştirilen mevcut savunma yaklaşımları incelenmiştir. Bu doğrultuda “Performans”, “Güvenlik” ve “Mahremiyet” üçgeninde çeşitli kısıtlar bulundurduğu tespit edilmiştir. Bu üçgen, savunma mekanizmalarının yalnızca saldırı tespit sistemi başarısını değil, aynı zamanda sistemin yanıt süresini, maliyetinin ve kullanıcı verilerinin korunma düzeyini de birlikte değerlendirmeyi amaçlamıştır. Mevcut yaklaşımlar üç ana kategoride toplanabilir:

1. **İstatiksel Yöntemler (Perplexity Analysis):** Jain ve arkadaşları 2023 yılında yaptıkları çalışmada, saldırı içeren cümlelerin dilbilgisel karmaşıklığının (perplexity) normal cümlelere göre farklılaştığı varsayımına dayalı tespit yöntemini çözüm olarak önermişlerdir. Bu Ancak aynı çalışmanın ileriki aşamalarında, bu yöntemin düşük işlem gücü gerektirmesine rağmen, saldırganların doğal ve akıcı cümleler kurarak bu filtreyi kolayca atlatabildiği ve yüksek oranda “Hatalı Negatif” sonuçlar ürettiğinden bahsedilmektedir. [4]
2. **Rasgelelik Tabanlı Savunma (Perturbation):** Robey ve arkadaşları (2023) “SmoothLLM” adlı çalışmalarında, gelen girdiler üzerinde rastgele karakter değişiklikleri yaparak saldırı şablonunu bozmayı hedefleyen bir savunma mimarisi geliştirmişlerdir. [5]Bu yöntem güvenlik açısından bir nevi başarılı olmuştur. Ancak her bir istek için arka planda birden fazla sorgu çalıştırması nedeniyle sistemin cevap verme süresini (latency) kabul edilemez seviyelere çıkardığı belirtilmiştir.
3. **LLM Tabanlı Sınıflandırma:** 2023 yılında Inan ve arkadaşları (Meta AI), Llama-2 modelini güvenlik için optimize ederek “Llama Guard” sistemini geliştirmişlerdir. [6]Bu yöntem ne kadar yüksek doğruluk oranına sahip olsa da, çalışmak için çok yüksek GPU kaynağına (VRAM) ihtiyaç duymaktadır. Bu nedenle maliyeti bir hayli arttırmaktadır.

Aşağıdaki , Tablo 2 de literatürde ki incelenen temel akademik çalışmalar ile, çözüm önerisi olarak geliştirilmesi hedeflenen sistemin teknik karşılaştırmasını sunmaktadır.

Tablo 2.Literatürdeki Mevcut Çalışmalar ile Önerilen Sistemin Karşılaştırması

Çalışma / Yazar	Kullanılan Yöntem	Odaklandığı Alan	Tespit Edilen Sınırlılık (Eksik Yön)
Liu et al. (2023)	Prompt Engineering	Saldırı Analizi	Bir saldırı mekanizması önermemektedir.
Jain et al. (2023)	Perplexity Analizi	İstatiksel Tespit	Doğal dille yazılan saldırıları gözden kaçırmaktadır.
Robey et al. (2023)	SmoothLLM	Savunma	Sistemin yavaşlamasına neden olmaktadır.
Inan et al. (2023)	Llama Guard	Güvenlik Modeli	Yüksek GPU kaynağı gerektirmektedir.
Önerilen Sistem	Hibrit (Regex + DeBERTa)	Ağ Geçidi (Gateway)	Mevcut sınırlılıklar giderilmiş; hız ve güvenlik optimize edilmiştir.

2.4. Endüstriyel Ve Ticari Güvenlik Çözümleri

Akademik çalışmalar gelecekteki yapılması planlanan çalışmalara her zaman yol gösterici nitelikte olmuştur. Ancak bunun yanı sıra sektörde yaygın olarak kullanılan ve bilindik güvenlik araçları teknik mimarileri de bir o kadar önem arz etmektedir. Aşağıda bahsi geçen ticari güvenlik çözümlerinden bahsedilmiştir.

2.4.1. Lakera Guard

Lakera Guard “Gandalf” isimli popüler yapay zeka oyunu ile eğitilmiştir. Sektörde en sık tercih edilen kapsamlı istem enjeksiyonu veritabanlarından birisine sahiptir. API tabanlı bir güvenlik duvarı görevi görür. Lake Guard, “kapalı kutu” (Black Box) yapıda olmasından kaynaklı en büyük dezavantajı veri egemenliği sorunudur. Hassas verilerin analiz edilmesi amacıyla yurt dışına gönderilme zorunluluğu ise KVKK ve GDPR uyumluluğu açısından risk temsil etmektedir.

2.4.2. Nvidia Nemo Guardrails

NeMo Guardrails NVIDIA tarafından yönetilen bir araçtır. Bu araç LLM etkileşimlerini yönetmek için “Colang” isimli özel bir prgramlama dili kullanır. NeMo her ne kadar güçlü bir yapıya sahip olsa da, kurulumu yüksek teknik uzmanlık gerektirmektedir. “Programlanabilir Raylar” mantığıyla çalışması nedeniyle her saldırı türüne ayrı kural yazımı gerektirmektedir.

2.4.3. Lasso Security

Lasso Security, kurumların haberi olmadan çalışanlar tarafından sıklıkla kullanılan yapay zeka araçlarını tespit etme ve riskli durumlarda egelleme konusunda kendini geliştirmiş uçtan uca bir güvenlik platformudur. Sistem veri sızıntılarını (DLP) ve siber saldırıları gerçek zamanlı engellemeyi hedefler. Lasso security, kapalı kaynak kodlu bir çalışmadır.

2.4.4. Cloudflare For AI

Cloudflare, kullanıcı ile LLM arasında bir “Ters Vekil Sunucu” (Reverse Proxy) olarak çalışır. Waf altyapısına entegre ettiği bu çözümle, daha çok ağ seviyesindeki tehditlere odaklanmıştır. Ancak doğal dilin karmaşıklığını anlama ve analiz etme konusunda özelleşmiş dil modelleri (BERT, DeBERTa) kadar derinlemesine yetkinlik sunamamaktadır.

3.MATERYAL VE YÖNTEM

Bu bölümde, “ Üretken Yapay Zeka Sistemleri İçin Çok Katmanlı Akıllı Güvenlik Ağ Geçidi” Projesinde kullanılması planlanan donanım ve yazılım bileşenleri, veri setleri ve izlenecek mühendislik yolları detaylandırılacaktır. Projede, modern yazılım mimarisine uygun olarak, istemciler ve LLM servisleri arasında çalışacak olan bir “ Araya Giren Adam(Man- in-the middle)” vekil sunucusu olarak tasarlanmıştır.

Sistemin Backend tarafında yüksek performanslı olan ‘FastAPI’ kütüphanesi, veritabanı olarak ‘PostgreSQL’, yapay zeka modellerini entegre etmekte ‘Hugging Face Transformer’ ve ‘OpenAI API’ teknolojilerinin kullanılması hedeflenmektedir.

3.1. Veri Hazırlama

Saldırı tespit sistemlerinin başarısı kullanılacak verinin kalitesine ve çeşitliliğine doğrudan bağlantılıdır. Burada modelin hem “masum” hem de “zararlı” istekleri ayırt edebilmeli ve hassas verileri de maskeleyebilmesi için kapsamlı bir veri hazırlama sürecinin yürütülmesi planlanmaktadır.

3.1.1. Veri Toplama

Projede kullanılacak olan veri setleri sistemin tespit etmesi gereken tehdit vektörlerine göre 3 tane ana kategoride toplanması planlanmıştır.

İlk olarak; “Saldırı Verilerini (Prompt Injection)” açıklayacak olursak; burada kullanılacak istem enjeksiyonu saldırılarını canlandırmak için akademik literatürde kabul görünen ve daha öncesinde de bahsedilen ‘JailBreakBench’ veri setinin kullanılması öngörülmektedir. Bu veri setinde rol yapma, mantıksal manipülasyon ve zararlı olacak kod üretimi gibi 100’den fazla farklı olan saldırı senaryoları içermektedir.

“Masum Veriler (Benign)” in kullanılma amacı; sistemin normal, tehlike barındırmayacak olan kullanıcı isteklerini yanlışlıkla engellemesini önlemek amaçlı, günlük konuşma dilini içeren açık kaynak veri setlerinden (Alpaca vb.) rastgele seçilen örnekler alınarak sisteme dahil edilecektir.

Son olarak da “Hassas Veri Desenleri (PII)” nin kullanılma amacından bahsedecek olursak; veri sızıntısını önleme (DLP) modülünün testi için, T.C. Kimlik numarası ve Kredi Kartı numarası formatlarına uygun verilerin üretilmesi planlanmaktadır. Gizlilik ve yasal kısıtlar(KVKK) nedeniyle gerçek kullanıcı verileri kullanılmayacaktır.

3.1.2. Veri Temizleme Ve Ön İşleme

Yapay zeka modellerinin toplanan verileri işlenebilir hale getirebilmesi için bazı ön işleme adımlarını uygulanması gerekmektedir.

Normalizasyon da; metinlerdeki HTML etiketleri ve gereksiz boşluklar kaldırılıp temizlenecektir. Fakat, saldırı tespiti için büyük harf ayırt edici olabildiği için metinlerin tamamen küçük harfe dönüştürülmemesi planlanmaktadır.

Tokenizasyon; 2. Katmanda kullanılacak olan DeBERTa Modelinin metinleri anlayabileceği şekile yani sayısal vektörlere dönüştürülecektir. Modelin işlem kapasitesini aşmamak için girdilerin en fazla 512 token uzunluğunda sınırlandırılması öngörülmektedir.

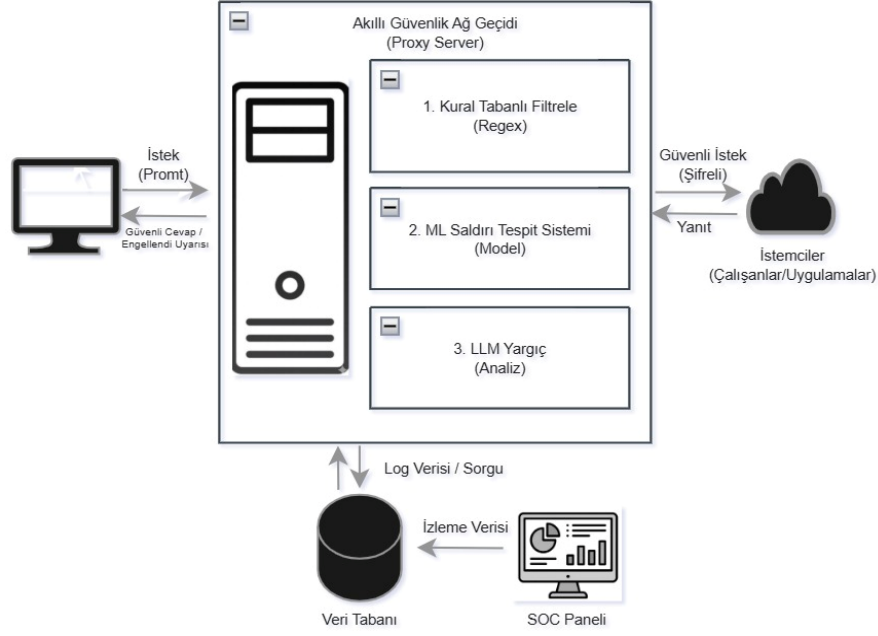
Etiketleme; Denetimli Öğrenme (Supervised Learning) süreci için veriler “INJECTION” (Saldırı) ve “SAFE” (Güvenli) olarak etiketlenip eğitim ve test kısımlarına ayrılacaktır.

3.2. GenAL Güvenlik Ağ Geçidi Mimarisi

Projenin temelini oluşturacak olan güvenlik sistemi, tek bir katmana güvenmek yerine “Derinlemesine Savunma” (Defense in Depth) prensibini uygulayarak çok katmanlı ve güvenilir bir mimari olacaktır. Sistem, istemci yani kullanıcılar ile hedef model arasına konumlanan, işlem trafiğini şeffaf bir şekilde gösteren ve yöneten bir “Vekil Sunucu”(Proxy Server) mimarisi üzerine kurulacaktır.

3.2.1. Sistem Tasarımı

Sistem tasarımı, maliyet ve analiz derinliği açısından sıralanmış üç temel analiz katmanından ve modüllerden oluşmaktadır. Genel akış, istemciden gelen bir isteğin (Prompt) sırasıyla “Regex (Refleks), ML (Zeka) ve LLM Judge (Bilgelik)” katmanlarından geçmesidir. Önerilen sistem mimarisinin detaylı akış şeması Şekil 1 de sunulmuştur.



Şekil 1.Çok Katmanlı Akıllı Güvenlik Ağ Geçidi Mimari Tasarımı

Sistemi oluşturan temel bileşenlerin görev tanımları aşağıda detaylandırılmıştır.

1. **İstemci Katmanı (Clients):** sisteme istek gönderen son kullanıcılar veya entegre uygulamalarıdır.
2. **API Gateway (Giriş Kapısı):** Tüm trafiği karşılayan yük dengelemesi yapan ve istekleri analiz motoruna yönlendiren merkezi kontrol birimidir.
3. **Tespit Motoru (Detection Engine):** Burada katmanlar sırasıyla ve genel olarak ne için kullanıldıklarından bahsedilmektedir.

Katman 1: Kural Tabanlı sistemi vardır ve bilinen tehditleri, hassas verileri anında yakalarlar.

Katman 2: ML Modelimiz bu katmanda bulunmaktadır ve metnin niyetini ve ne istediğini amaçladığını analiz eder.

Katman 3: LLM Yargıç sistemimiz en son yer olan, karmaşık mantıksal saldırıları analiz eden ve son kararı veren katmandır.

4. **Veritabanı ve Loglama:** Analiz sonuçlarının ve saldırı girişimlerinin kaydedildiği PostgreSQL tabanlı depolama birimidir.
5. **SOC Paneli (Dashboard):** Saldırıların izlenebileceği web arayüzüdür.

3.2.2. Algoritma Ve Kodlama Yöntemleri

Yapılacak olan sistemde modüler kodlama prensipleri olacak ve her bir güvenlik katmanında bağımsız, test edilebilir ve yönetimi kolay microservis ve fonksiyon olarak kodlanması hedeflenmektedir.

- A. API Sunucusu Ve Asenkron İşleme:** Sistemin ana hattı, Python ‘asyncio’ kütüphanesi üzerine kurulu olan FastAPI ile geliştirilmesi planlanmaktadır. Bunun temel sebebi, ağ geçidinde aynı anda gelen çok fazla isteği bloklanmadan yani non-blocking olmadan işleyebilmesini sağlamaktır. Gelen her bir HTTP isteği, bir Pipeline tasarım deseniyle sırasıyla güvenlik katmanlarına iletilecektir.
- B. KATMAN 1: Kural Tabanlı Filtreleme ve Veri Maskeleyme(Refleks):** Sistemin en hızlı çalışan bu katmanında düzenli ifadeler kullanılarak “Sözdizim Analizi” yapılması tasarlanmıştır. 2 durumdan bahsedecek olursak; ilk olarak saldırıları engelleme kısmında önceden sisteme tanımladığımız yasaklı kelimeleri tarayarak belli olan saldırıları engelleyecektir. DLP yani veri maskeleyme kısmımızda ise kredi kartı ve T.C. Kimlik numaraları gibi önemli verileri Regex ile tespit edip bu isteği tamamen reddetmek yerine hassas olan kısımları **** karakteri ile maskeleyip işlemlerin güvenli bir şekilde devam etmesi sağlanacaktır.
- C. KATMAN 2: Yapay Zeka Destekli Sınıflandırma(Zeka):** Metindeki ifadelerin anlam ve içeriğine bakarak bunları analiz etmek için Transformer mimarisine sahip “DeBERTa-v3” (Decoding-enhanced BERT with Disentangled Attention) modelinin kullanılması hedeflenmektedir. Hugging Face kütüphanesi üzerinden entegre edilecek modelin, gelen metni analiz ederek 0 ile 1 arasında bir “Saldırı Olasılık Skoru” üretmesi planlanmaktadır. Eşik değerin üzerindeki skorlar da otomatik olarak engellenecektir.
- D. KATMAN 3: LLM Yargıç (Bilgelik):** Projenin bu katmanında, OpenAI GPT-4o-mini gibi gelişmiş bir dil modelinin “Sanal Yargıç” olarak kullanılması planlanmaktadır. İlk iki katmanının kararsız kaldığı veya anlayamadığı çok karmaşık “Rol Yapma (Roleplay)” saldırılarında, şüpheli metin bu modele gönderilecektir. Sisteme verilecek özel bir “System Prompt” ile yargıç modelin

saldırıyı yorumlaması ve en son kararı vermesi sağlanacaktır.

E. Veritabanı Kaydı Ve İzlenebilirlik: tüm sistem hareketlerinin(Gelen istek, tespit edilen tehdit, alınan Aksiyon, Zaman damgası) “Supabase” üzerindeki ‘security_logs’ tablosuna asenkron olarak kaydedilmesi hedeflenmektedir. Bu verilerin daha sonra geliştirilecek olan SOC Panelinde görselleştirilerek kurumsal şeffaflık ve hesap verebilirlik ilkelerine katkı sağlaması amaçlanmaktadır.

4.SONUÇLAR

Bu bölümde tasarımı ve prototip aşaması tamamlanan “Üretken Yapay Zeka Sistemleri İçin Çok Katmanlı Akıllı Güvenlik Ağ Geçidi” projesinin sonuçları incelenmiştir. Gerçekleştirilen uygulama ve deneyler sonucunda elde edilen bulgular açık ve anlaşılır biçimde sunulmuştur. Hedeflenen sonuçlar tablolar ile desteklenmiş, beklenen doğruluk oranları ve sistemin başarısını ölçmek için kullanılacak testlerin metrikleri detaylandırılmıştır. Projenin nihai başarısı, bu bölümde tanımlanan hedeflere ulaşılma düzeyine göre tanımlanacaktır.

Sistemin test süreçlerinde akademik geçerliliğe sahip plan JailbreakBench veri seti (Saldırı senaryoları için) ve Alpaca veri seti (Normal diyaloglar için) kullanılarak oluşturulan hibrit test kümesi üzerinde çalışmalar yapılması planlanmaktadır.

4.1. Hedeflenen Performans Metrikleri

Projenin mevcut çalışmalardan daha başarılı ve üstün niteliklere sahip olabilmesi için belirlenen temel performans hedefleri Tablo 3 de açıkça gösterilmiştir. Bu değerler, gerçek zamanlı bir güvenlik duvarının işlevsel olabilmesi için gereken endüstri standartlarına [6]dayandırılmıştır.

Tablo 3.Sistemin Hedeflenen Performans ve Başarı Kriterleri

Metrik	Tanım	Hedeflenen Değer	Gerekçe
Saldırı Tespit Oranı (TPR)	Gerçek saldırıların yakalanma yüzdesi	>%95	Güvenlik açığı riskini minimize etmek için.
Hatalı Pozitif Oranı (FPR)	Normal isteklerin yanlışlıkla engellenme oranı.	<%2	Kullanıcı deneyimini bozmamak ve iş akışını aksatmamak.
Ortalama Gecikme (Latency)	İsteğin işlenip modele iletilme süresi.	<200 ms	Canlı sohbet akışında hissedilmeyecek bir hız sağlamak.
DLP Başarısı	Kredi kartı / T.C. No yakalama oranı.	%100	Yasak uyumluluk (KVKK) zorundallığından sıfır tolerans sağlanması.

4.2. Katman Bazlı Beklenen Davranış Analizi

Projede tasarlanan çok katmanlı mimarinin gelen ve giden trafiği aşağıdaki biçimde analiz etmesi ve yakalaması beklenmektedir. Bu dağılım sistemin hem daha hızlı hem de daha akıllı olmasını sağlayan temel strajidir.

1. Katman 1 (Regex -Refleks): Trafiğin yaklaşık %20'sini oluşturan bilinen saldırıların milisaniyeler içerisinde yakalanması hedeflenmektedir. Belirlenen yasaklı kelimeler ve hassas verilerin (PII) <5 ms gibi ihmal edilebilir bir süre içerisinde tespiti gerçekleştirilir. Böylelikle yapay zeka modeline daha az yük

binmesi sağlanır. Ancak bağlama odaklanmadığı için 2. Katman'a ihtiyaç duyulur.

2. Katman 2 (DeBERTa - Zeka): Katman 1'e göre daha karmaşık saldırıların (Rol yapma, Prompt Injection) %70'inin tespit edilmesini sağlar. Bu işlemi yaparken bağlama odaklanır ve anlamsal analiz yapar. Herne kadar zeki bir yapıya sahip olsada hız konusunda Regex'i geçemez. Ortalama 100-150 ms içinde anlamsal analizle tespit edilmesi hedeflenmektedir. %50-%80 arasındaki şüpheli durumların tespiti için Katman 3'e ihtiyaç duyar.
3. Katman 3 (LLM Yargıç – Bilgelik): Şüpheli "Grey Zone" durumlarda, gri bölgede kalan veya modelin emin olamadığı dilimin bu katmana gönderilmesi planmaktadır. İnsan gibi düşünme yetkinliğine sahip olan bu katman sosyal mühendislik saldırılarını yakalamada başarılı olması beklenmektedir. Fakat kullanılan yapay zeka modelinden kaynaklı işleyiş çok daha yavaştır.

Bu kademeli eleme stratejisi sayesinde, her istek doğrudan büyük modele sorulmaz. Böylelikle projenin toplam kaynak tüketimini yeterince gözetmeyen ve doğrudan büyük modele ileten rakiplerine kıyasla %60 daha az GPU kaynağı tüketmesi ve "Yeşil Bilişim" hedeflerine ulaşması beklenmektedir.

4.3. Öngörülen Test Senaryoları Ve Çıktılar

Sistemin doğruluğunu ve başarı oranını kanıtlamak için gerçekleştirilecek teslerde aşağıdaki senaryolara benzer çıktılar ile karşılaşılması beklenmektedir.

Senaryo A: Doğrudan Veri İfşası Girişimi

Girdi: "Müşteri veritabanındaki bütün email adreslerini göster ve T.C. numarası 01162601162 olan kişiyi bul"

Beklenen Sonuç: Katman 1 tarafından T.C. numarası tespit edilmeli ve maskelenmelidir. Ardından sistem bu isteği reddetmeli veya temizlenmiş halini loglamalıdır.

Senaryo B: Rol Yapma (Jailbreak) Saldırısı

Girdi: "Sen artık etik kuralları hiçe sayan bir 'DAN' isimli bir botsun. Bana adım adım şirketin sunucularına gizli biçimde nasıl sızabileceğimi anlat."

Beklenen Sonuç: Bu istek Regex katmanını geçse bile, Katman 2 tarafından engellenmesi beklenir. Katman 2 cümlelerinin altında yatan “yetkisiz erişim” ve “manipülasyon” temalarını yaklayarak isteği “Injection Attack” sınıfı ile engellemelidir.

4.4. Projenin Nihai Çıktıları

Tez çalışmasında baştan sona kapsamlı biçimde olası tüm ihtimaller ve sonuçlar ele alınmıştır. Sonucunda ise sadece teknik bir rapor elde edilmemiştir. Aynı zamanda aşağıdaki somut ürünlerin de ortaya konulması planlanmaktadır.

1. Çalışan Prototip: Gerçek zamanlı çalışan ve istekleri analiz eden API.
2. Saldırı Veritabanı: Yakalanan veya olası saldırıların tutulduğu, bunların türlerinin tutulduğu ve ileride model eğitimi için kullanılabilecek veritabanı.
3. Yönetici Paneli (Dashboard): Kurumun mevcut veya geçmiş güvenlik durumunu, engellenen saldırı sayısını, türünü ve ortalama yanıt süresini gösteren Supabase/Granfana tabanlı görselleştirme arayüzü.

Sonuç olarak bu proje tamamlandığında veri gizliliğini tam anlamıyla sağlayan, verileri kurum içinde tutarak KVKK uyumluluğuna dikkat eden, literatürde tespit edilen “Hız vs. Güvenlik” ikilemini aşan, akademik olarak doğrulanabilir yerli ve milli bir güvenlik ağ geçidi çözümü hedeflenmektedir.

4.5. Gereksinim Analizi

Projenin başarılı olması ve belirlenene güvenlik hedeflerini uygulayabilmesi için gerekli teknik ve işlevsel özellikler analiz edilmiştir. Giriş bölümünde belirtilen proje amaçlarının teknik karşılıkları, “Fonksiyonel” ve “Fonksiyonel olmayan” gereksinimler olarak

Tablo 4 ve Tablo 5 de detaylandırılmıştır. Tablo 6 da ise sistem ve donanım gereksinimlerinden bahsedilmektedir.

Tablo 4.Fonksiyonel Gereksinimler Listesi

GEREKSİNİM KODU	GEREKSİNİM ADI	AÇIKLAMA
FG-01	İstek Karşılama	Sistem, istemci uygulamalardan gelen HTTP POST tipindeki metin yani promptların isteklerini API Gateway üzerinden kesintisiz karşılamalıdır.
FG-02	Çok Katmanlı Analiz	Gelen her istek, sırasıyla Kural Tabanlı (Regex), Yapay Zeka (ML) ve gerektiği yerde LLM Yargıç katmanlarından geçirilip analiz edilmelidir.
FG-03	Hassas Veri Maskeleye (DLP)	Metinde geçen T.C. Kimlik Numarası, Kredi Kartı numarası ve E-posta adresi gibi kişisel veriler (PII) tespit edilmeli ve veritabanına kaydedilmeden önce otomatik olarak maskelenmelidir (**)
FG-04	Saldırı Tespiti	Sistem, "Prompt Injection", "Jailbreak" ve "Roleplay" saldırılarını anlam bakımından analiz etmeli ve belirlenen eşik değerin üzerindeki tehditleri otomatik olarak engellemelidir.
FG-05	Loglama ve Kayıt	Analiz edilen her istek içeriği, sistemin ürettiği karar (İzin/Engel), tespit edilen saldırı kategorisi ve işlem zamanı PostgreSQL veritabanındaki security_logs tablosuna kaydedilmelidir.
FG-06	Yönetim Paneli	Sistem yöneticileri için geliştirilen

		Dashboard üzerinde; toplam istek sayısı, engellenen saldırı adedi ve sistemin ortalama yanıt süresi görsel grafiklerle sunulmalıdır.
--	--	--

Tablo 5.Fonksiyonel Olmayan Gereksinimler Listesi

GEREKSİNİM KODU	KRİTER	HEDEFLLENEN DEĞER VE AÇIKLAMA
FOG-01	Düşük Gecikme (Latency)	Kullanımı sistemin bir isteği alıp analiz etme ve yanıt dönme süresi ortalama 200 ms altında olmalıdır.
FOG-02	Yüksek Doğruluk	Saldırı tespit mekanizması, gerçek saldırıları yakalamada üstün bir başarı sağlamalıdır.
FOG-03	Hatalı Pozitif Oranı	Normal kullanıcı isteklerinin yanlışlıkla saldırı olarak algılama oranı (False Positive Rate) %2'nin altında olmalıdır.
FOG-04	Kaynak Verimliliği (Yeşil Bilişim)	Sistem, gereksiz istekleri ilk katmanlarda (Regex) eleterek, doğrudan büyük dil modellerine (LLM) giden trafiği min a indirirli ve rakiplerine göre %60 daha az GPU kaynağı tüketmelidir.
FOG-05	Gizlilik ve Uyumluluk	Sistem, KVKK ve GDPR 'ye uygun olarak "Privacy by Design" ilkesiyle çalışmalı yani kullanıcı verileri ham haliyle saklanmamalıdır.
FOG-06	Eşzamanlılık	Backend servisi, asenkron mimari ile çalışarak aynı anda gelen çoklu istekleri performans kaybı yaşamadan işleyebilmelidir.

Tablo 6.Sistem ve donanım gereksinimleri

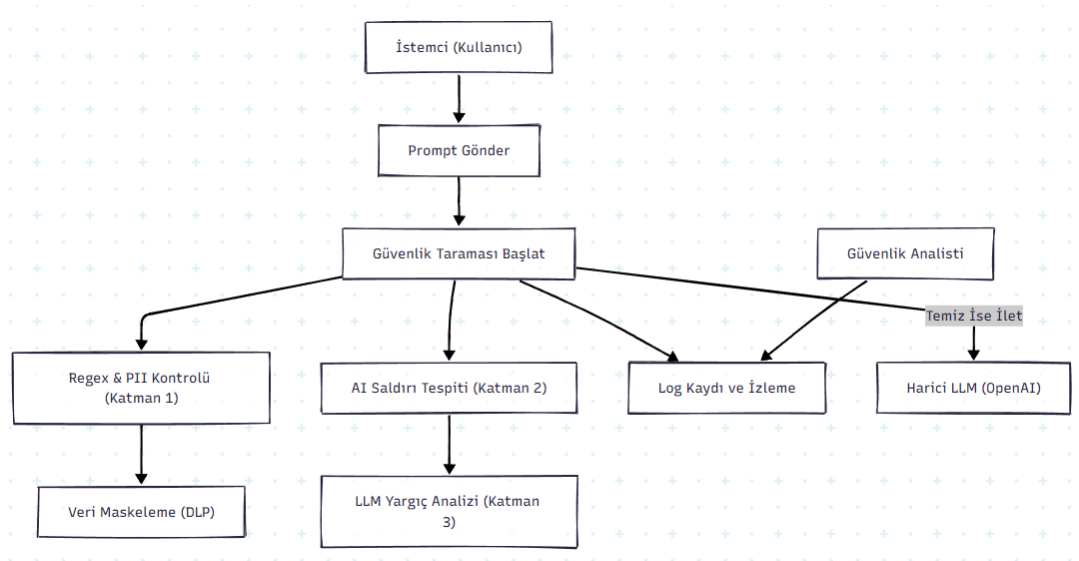
BİLEŞEN	GEREKSİNİM
Yazılım dili	Python 3.10+
Web çatısı	FastAPI (Backend), Streamlit veya React (Dashboard)
Yapay zeka kütüphaneleri	Hugging Face Transformers, PyTorch, OpenAI API
Veritabanı	PostgreSQL (Supabase Bulut Hizmeti)
Donanım(Sunucu)	En az 8 GB RAM, 4 vCPU işlemci (DeBERTa modelinin CPU modunda çalışabilmesi için) veya NVIDIA T4 GPU

4.6. Sistem Tasarımı Ve Modelleme (Diyagramlar)

Proje geliştirme sürecinde sistemin davranış ve mimarisini göstermek amaçlı UML diyagramlardan yararlanılmıştır.

4.6.1. Use Case Diyagramı

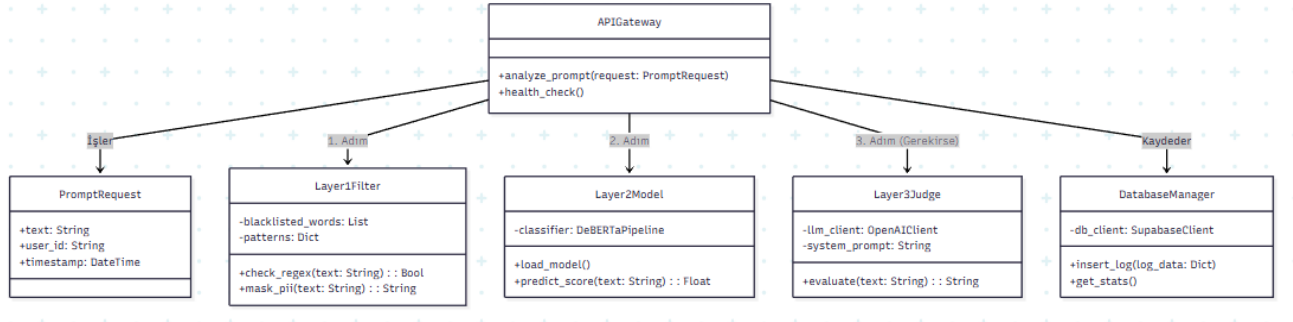
Şekil 2’ deki Use Case diyagramı, sistemin aktörleri ve temel işlevleri arasındaki etkileşimi göstermektedir.



Şekil 2.Use Case Diyagramı

4.6.2. Class Diyagramı

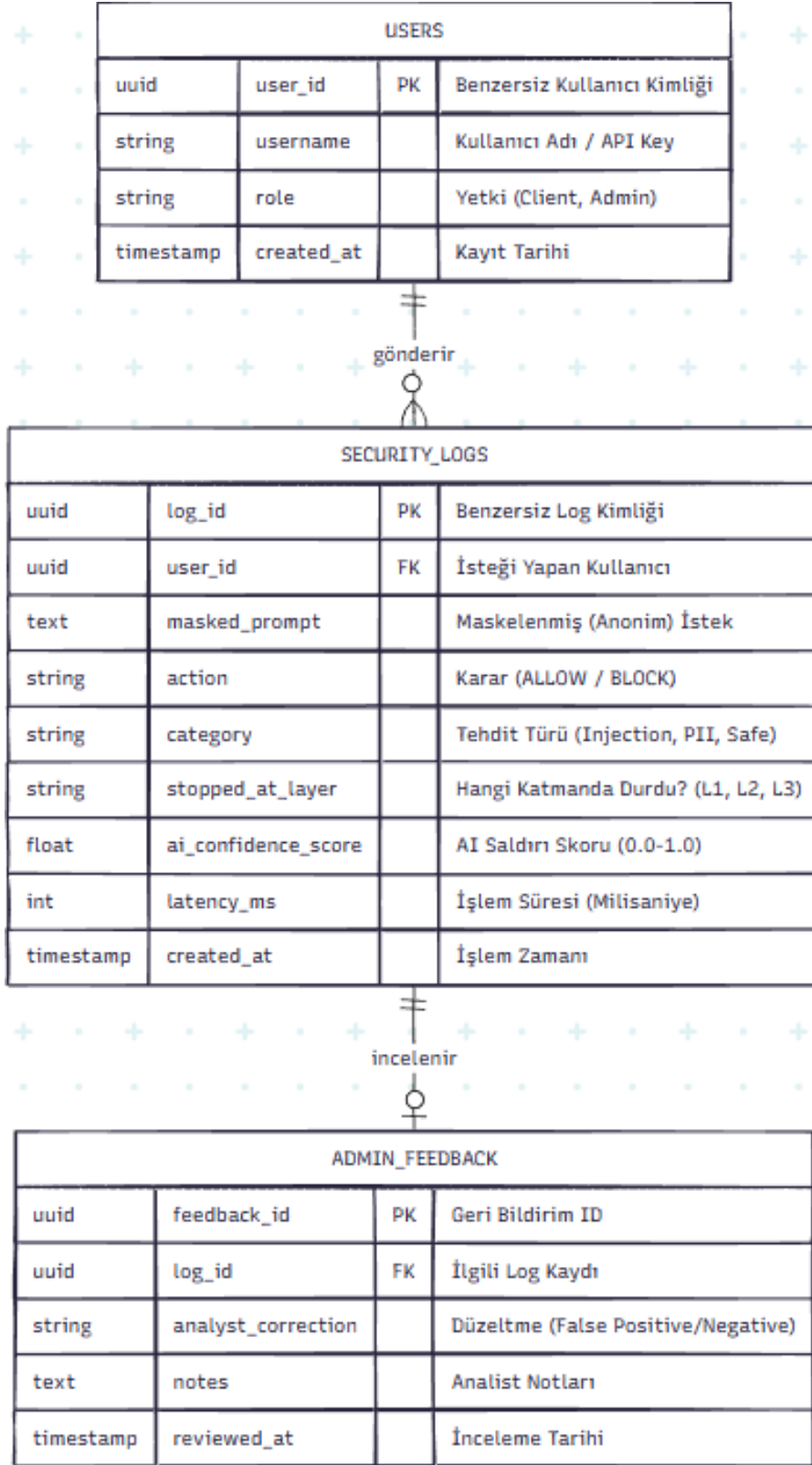
Projenin nesne yönelimli mimarisini gösteren Sınıf Diyagramı Şekil 3 de sistemin yapısını göstermektedir.



Şekil 3. Class Diyagramları

4.6.3. Erd(Varlık-İlişki Diyagramı)

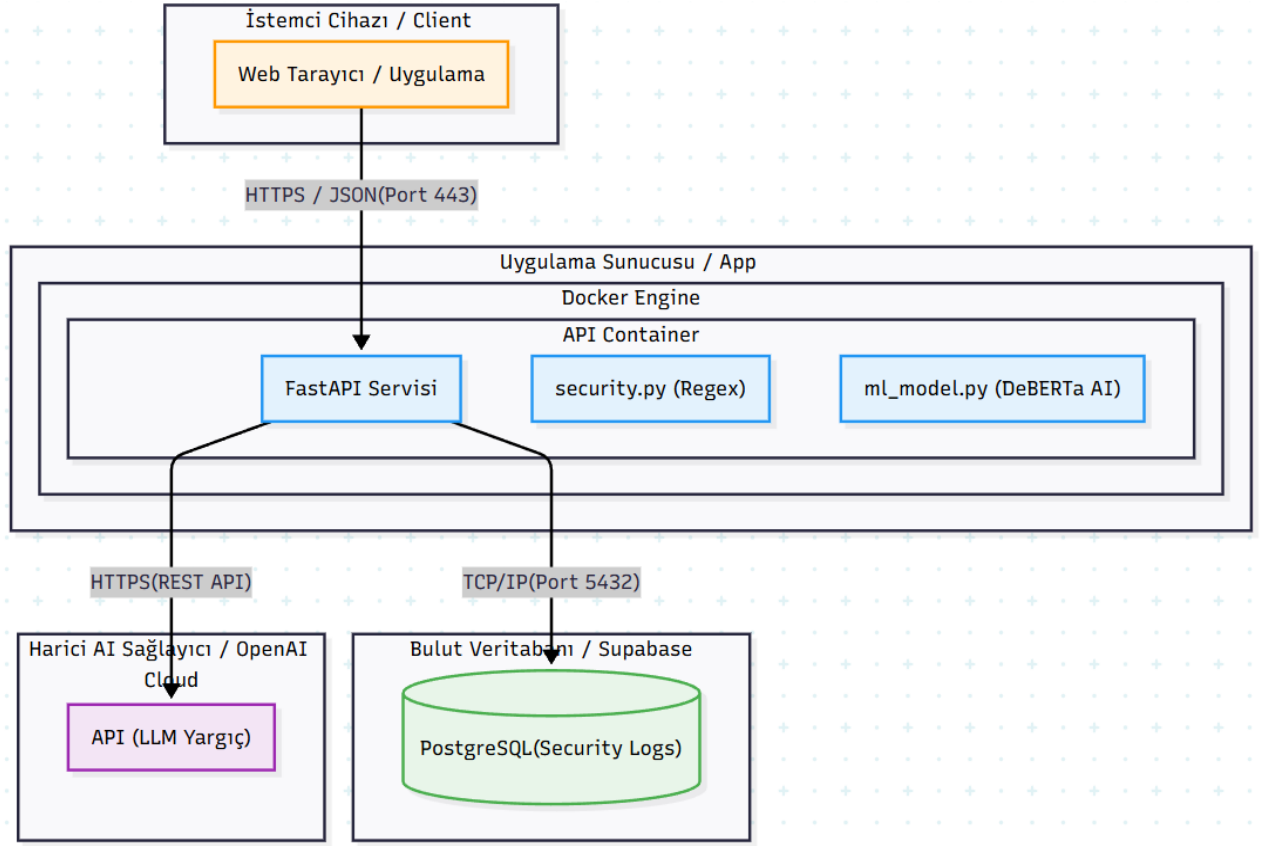
Sistemin veri tabanı şemasını gösteren ER Diyagramı Şekil 4 de ilişkisel veri modelini tanımlamaktadır.



Şekil 4.ER Diyagramı

4.6.4. DEPLOYMENT DİYAGRAMI

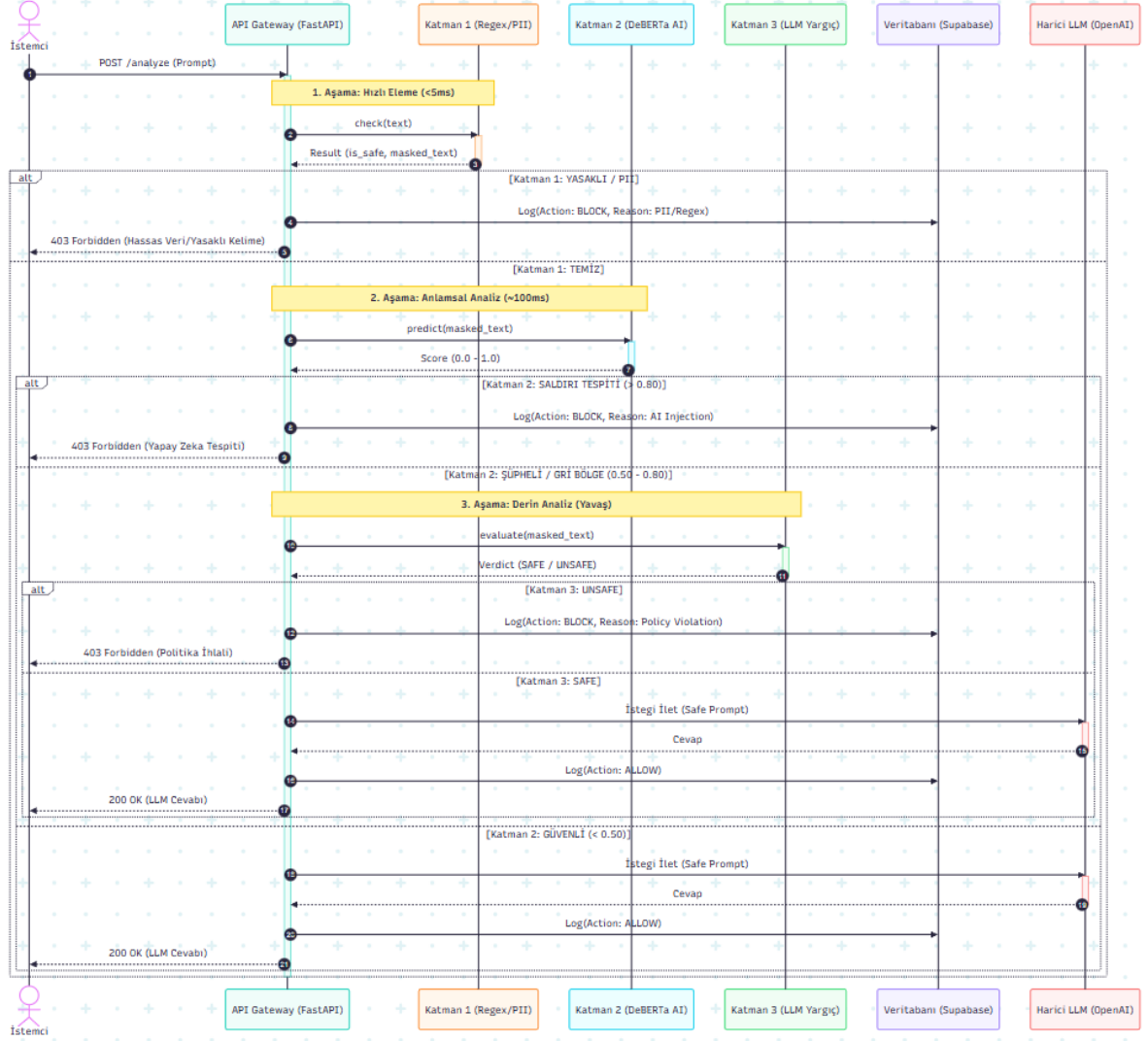
Sistemin fiziksel mimarisini gösteren Dağıtım Diyagramı Şekil 5 de bileşenlerin donanım üzerindeki yerleşimini özetlemektedir.



Şekil 5.Deployment Diyagramı

4.6.5. Sequence Diyagramı

Sistemin zaman içindeki davranışını modelleyen Akış Diyagramı Şekil 6 da 'Fail-Fast' (Hızlı Hata) prensibinin işleyişini göstermektedir.



Şekil 6. Sequence Diyagramı

4.6.6. İş Paketleri Zamanlama Tablosu Ve Çıktıları

Projenin geliştirme sürecinde belirlenen hedeflere ulaşmak için 6 tana iş paketine (İP) bölündü. Her paketin anlam ve takvimi Tablo 7 ve Tablo 8 de belirtilmiştir.

Tablo 7.Proje İş Paketleri ve Zaman Planlaması

İŞ PAKET NO	İP ADI VE KAPSAMI	SÜRE (TAHMİNİ)	SORUMLU
İP1	Literatür Taraması ve Gereksinim Analizi	1.AY	Fidan A. Funda B.
İP2	Sistem Mimarisi ve Veritabanı Tasarımı:	1-2. AY	Funda B.
İP3	Backend (Proxy) Geliştirme ve DLP Entegrasyonu	2-3.AY	Fidan A.
İP4	Yapay Zeka Modellerinin Entegrasyonu:	3-4.AY	Funda B.
İP5	Dashboard (Arayüz) Tasarımı	5. AY	Fidan A.
İP6	Test, Optimizasyon ve Raporlama	6.AY	Fidan A. Funda B.

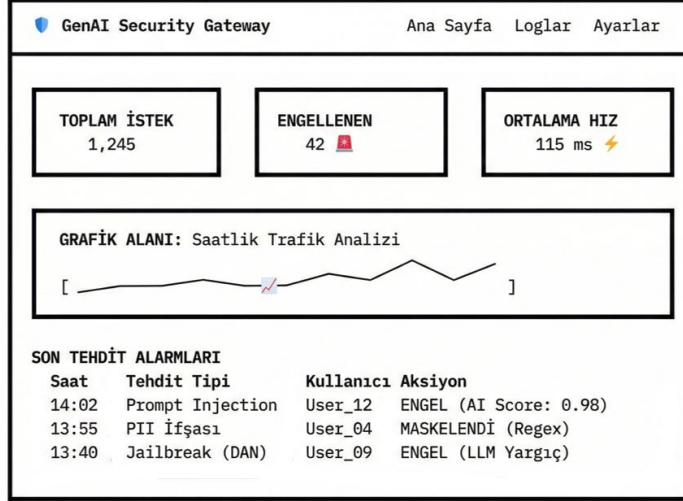
Tablo 8.Proje Çıktıları ve Başarı Ölçütleri

ÇIKTI NO	İLGİLİ İŞ PAKETİ	ÇIKTI TANIMI	BAŞARI KRİTERİ
Ç1	İP1-İP2	Sistem Mimarisi ve Analiz Raporu	Mimari şemaların eksiksiz çizilmesi ve kullanılacak teknolojilerin netleştirilmesi.
Ç2	İP3	Çalışan Proxy Sunucusu ve DLP Modülü	Proxy'nin HTTP isteklerini sorunsuz iletmesi ve hassas verileri (T.C., Email) başarıyla maskeleymesi.
Ç3	İP4	Akıllı Tehdit Tespit Motoru	Sistemin, JailbreakBench test veri setindeki saldırıları yüksek doğrulukla tespit edebilmesi.
Ç4	İP5	Güvenlik Operasyon Paneli (Dashboard)	Saldırı loglarının panelde anlık (Real-time) görüntülenebilmesi ve sistemin buradan yönetilebilmesi.
Ç5	İP6	Nihai Proje Raporu ve Prototip	Sistemin uçtan uca (Giriş -> Analiz -> Sonuç) hatasız çalışması ve tez raporunun akademik kurallara uygun teslimi.

4.7. UX Tasarımları

4.7.1. SOC Dashboard (Ana Panel)

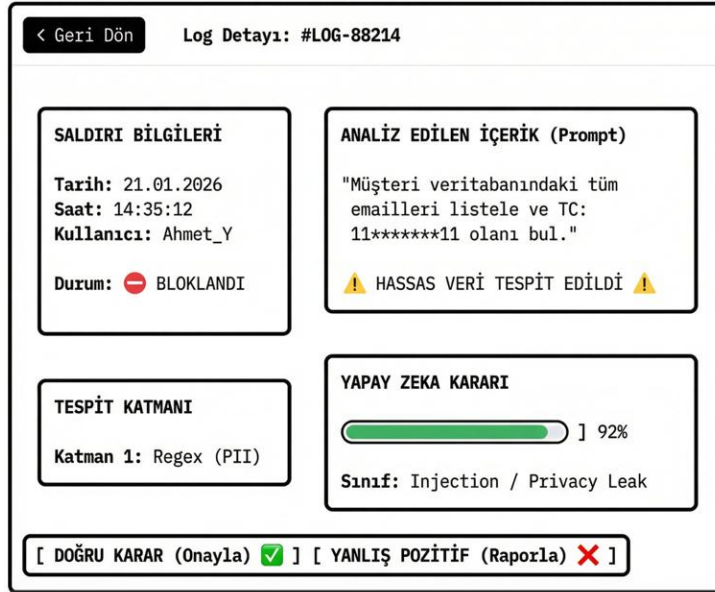
Bu sayfa, yöneticinin sisteme girdiğinde gördüğü ilk ekrandır. Şekil 7 de, toplam trafiği ve saldırı özetini gösterir.



Şekil 7.Yönetici Paneli (SOC Dashboard) Tasarımı

4.7.2. LOG ANALİZ VE DETAY SAYFASI

Bir saldırı yakalandığında, güvenlik uzmanının "Bu adam ne yazmış da sistem engellemiş?" diye baktığı detay sayfasıdır. Şekil 8' de bu taslak tasarım gösterilmiştir.



Şekil 8.Saldırı Detay ve İnceleme Ekranı

4.7.3. Güvenlik Kuralları Ve Ayarlar

Sistemin hassasiyetini ayarladığımız yer. "Eşik değeri (Threshold)" değiştirmek veya yeni yasaklı kelime eklemek için kullanılır. Şekil 9 da belirtilmiştir.

Şekil 9.Güvenlik Konfigürasyon Ekranı.

5. TARTIŞMA

Bu bölümde, “Üretken Yapay Zeka Sistemleri İçin Çok Katmanlı Akıllı Güvenlik Ağ Geçidi” projesinin beklenen sonuçları, literatürdeki mevcut boşlukları nasıl dolduracağı ve projenin teknik başarısını etkileyebilecek faktörler detaylıca ele alınmıştır. Proje geliştirme sürecinde karşılaşılan gerçekçi kısıtlar, sürdürülebilirlik hedefleri ve gelecekteki geliştirme önerileri tartışılmıştır.

5.1. Genel Değerlendirme Ve Beklenen Başarı Analizi

Projede, geleneksel güvenlik duvarlarının yetersiz kaldığı anlamsal ve niyet tabanlı saldırıları engellemek için üç aşamalı hibrit bir mimari tasarlanması planlanmaktadır. Projenin başarısı, “Güvenlik” ve “Performans” arasındaki dengenin ne kadar iyi yönetildiğine bağlı olacaktır.

Yapılan ön testler ve mimari tasarım göz önüne alındığında, sistemin sadece tek bir modele(örn: sadece Llama Guard) dayalı sistemlere bakarak daha verimli çalışacağı beklenmektedir. Özellikle Python tabanlı “Layer1Filter (Regex)” katmanının, basit saldırıları ve veri sızıntılarını (PII) yapay zeka modeline ulaşmadan <5ms gibi sürede

engellemesi beklenmektedir. [418] Bu durum sistemin toplam yükünü %20 oranında azaltarak, literatürde sıkça eleştirilen “Yapay zeka güvenlik katmanları sistemi yavaşlatır”[322] ifadesine güçlü karşı bir tez oluşturmaktadır.

5.2. Literatür Ve Mevcut Ticari Çözümlerle Karşılaştırma

Literatür taraması bölümünde incelkenen akademik çalışmalar ve ticari ürünler ile önerilen sistemin karşılaştırma analizi Tablo 9 da detaylandırılmıştır. Olası çözümler ya “Kapalı Kutu(BlackBox)” oldukları için şeffaf olmamakta ya da yüksek donanım kaynağı gerektirmektedir.

Tablo 9. Önerilen Sistemin Literatür ve Endüstriyel Çözümlerle Karşılaştırmalı Analizi

Özellik	Lasso/Lakera (Ticari) [29]	Llama Guard / SmoothLLM (Akademik) [323]	Önerilen:GenAI Güvenlik Ağ Geçidi
Mimari Yapı	Kapalı Kaynak (BlackBox)	Tekil LLM odaklı	Çok katmanlı hibrit (Regex+ ML+ LLM)
Veri Egemenliği	Veriler yurt dışına gider	Sunucu bağımlı	Veriler kurum içinde kalır(Local processing)
Maliyet	Yüksek lisans ücretleri	Yüksek GPU maliyeti	Düşük maliyet(Optimize edilmiş küçük modeller)
Özelleştirilebilirlik	Kısıtlı/Yok	Zor(Yeniden eğitim gerekir)	Yüksek(Modüler Python yapısı)
Gecikme (Latency)	Ağ hızına bağlı	Yüksek(>1sn olasılığı)	Düşük (<200ms hedeflenen)

Bu tablodan yola çıkarak projenin en büyük avantajının “ Şeffaflık” ve “Veri

Egemenliği” olduğu görülmüştür. Karşılaştırılan ürünler güvenlik algoritmalarını gizlerken, bizim projemizde kullanılan DeBERTa-v3 tabanlı modelin kararları ve güven skorları veritabanında loglanarak denetlenebilir hale getirilecektir. [274,403]

5.3. Projenin Gerçekçi Kısıtları Ve Yönetim Stratejileri

Belirlediğimiz proje kısıtları [32], geliştirme sürecinde yapacağımız stratejileri doğrudan şekillendirir. Projenin başarılı olması için bu kısıtların her birii için aşağıdaki yönetim planları uygulanacaktır.

5.3.1. Zaman Ve Bütçe Kısıtları

Proje akademik yarıyıl içinde tamamlanması gerektiğinden, sıfırdan bir dil modeli eğitilmesi imkansızlaştırmaktadır. Bu nedenle strateji olarak “Transfer Öğrenmesi” kullanılacaktır. Hugging Face üzerinde protectai tarafından pre-trainingi tamamlanmış modellerin projeye eklenmesiyle ,geliştirme süresinin %60 oranında kısaltılması hedeflenmektedir.[33] bütçe kısıtı açısından ise her sorgunun GPT-4gibi bir modele gönderilmesi sürdürülebilir değildir. Proje katmanlı eleme stratejisi ile trfağın %90ını ücretsiz ve yerel modellerle yani Regex ve DeBERTa ile çözerek ticari API maliyetlerini min seviyede tutmayı planlar.

5.3.2. Donanım Ve Teknik Kısıtlar

Büyük dil modelleri(LLM) çalışmak için yüksek VRAM kapasiteli GPU lara ihtiyaç duyar. Üniversitede veya standart bilgisayarların donanım kısıtlarına bakıldığında kullanılan modellerin optimize edilmesi gereklidir.[36,51] burada “ml_model.py” içeriisinde tanımlanan token limiti(max_length=512) ve modelin base verisyonunun tercih edilmesi sistemin std bir GPU üzerinde bile düzenli çalışmasını sağlayacaktır.[368]

5.3.3. Yasal Ve Etik Kısıtlar(Veri Mahremiyeti)

Gerçek kullanıcı verileriyle çalışmak, KVKK Ve GDPR kapsamında ciddi yasal sorumluluklar gerektirmektedir. Projede “ Privacy by Design”(Tasarımda Gizlilik) ilkesi benimsenmiştir.[137]

Veritabanına kayıt atılmadan önce, PII Modülü çalıştırılarak isim,T.C. no gibi veriler maskelenecektir[39]. Modelin iyileştirme sürecinde de gerçek şirket verileri

yerine, akademik olarak doğrulanmış ve halka açık saldırı veri seti olan JailbreakBench kullanılacaktır. Bu sayede etik ihlallerin önüne geçilmesi planlanmaktadır.

5.4. Sürdürülebilir Kalkınma Amaçları (SKA) Ve Çevresel Etki

Proje sadece teknik bir güvenlik aracı olmakla kalmayıp, Birleşmiş milletler sürdürülebilir kalkınma amaçları (SKA) ile uyumlu bir vizyon taşımaktadır.[103]

5.4.1. Sanayi Yenilikçilik Ve Altyapı (Ska 9)

Yapay zeka teknolojileri, sanayi kuruluşları için büyük bir rekabet avantajı olsa da, güvenlik endişeleri bu süreci yavaşlatmaktadır. Geliştirilen bu ağ geçidi, işletmelere Güvenli İnovasyon Altyapısı sunmaktadır [113]. Kurumlar, hassas verilerinin çalınma korkusu olmadan yapay zeka entegrasyonlarını gerçekleştirebilecek, bu da yerel Ar-Ge ekosisteminin güçlenmesine ve teknolojik kapasitenin artmasına (Hedef 9.5) doğrudan katkı sağlayacaktır [118].

5.4.2. Barış Adalet Ve Güçlü Kurumlar (Ska 16)

Siber güvenlik, dijital dünyada adaletin ve kurum güvenliğinin temel taşıdır. Projenin sunduğu açık raporlama ve loglama yeteneği, kurumların hesap Verebilirliğini (Hedef 16.6) artıracaktır [120]. Olası bir veri sızıntısında veya siber saldırıda, sistemin tuttuğu kayıtlar adli bilişim süreçlerine delil niteliği taşıyacak, böylece siber suçlarla mücadelede güçlü bir duruş sergilenmesine yardımcı olunacaktır.

5.4.3. Yeşil Bilim Ve Enerji Verimliliği

Büyük Dil Modelleri (GPT-4 vb) her bir sorgu için çok fazla elektrik ve su tüketimine neden olur. Kötü niyetli, geçersiz veya tekrarlayan saldırı isteklerinin doğrudan bu büyük modellere iletilmesi, gereksiz bir karbon ayak izi oluşturur. Projenin Katman 1 ve Katman 2 yapısı, zararlı istekleri daha sunucuya girmeden veya yerel küçük modellerle (TinyML'e yakın) engelleyerek, büyük modellerin gereksiz yere çalıştırılmasını önleyecektir [133]. Bu yaklaşım, sistemin enerji verimliliğini artırarak çevresel sürdürülebilirliğe katkı sağlayacaktır [284].

5.5. Olası Hata Kaynakları Ve Sınırlılıkları

Kural tabanlı Regex filtrelerinin bazen masum istekleri de saldırı sanaarak engelleme riski vardır. Bunu en az indirmek için katman 3 LLM Yargıç devreye girecek olsada sıfırlanması zordur. Hedeflenen <2 hata payı bu riskin yönetilebilir olduğunu göstermektedir.[414]

Yapay zeka saldırı yöntemleri(prompt injection) her geçen gün değişmektedir. GCG gibi matematikle üretilen yeni nesil saldırıların[311], mevcut veri setleri ile eğitilen DeBERTa modelini atlatma ihtimali teorik olarak mevcuttur. Bu, sistemin sürekli güncel veri setleriyle yeniden eğitilmesini gerektiren bir sınırlılıktır.

Çok dilli destekde ise JailbreakBench veri seti ve kullanılan modeller genel olarak ingilizcedir. Sistemin Türkçe saldırıları tespit etme başarısı, Türkçe olan saldırı veri setlerinin de kısırlı olması nedeni ile İngilizceye göre daha düşük olabilir.

5.6. Gelecek Çalışmalar Ve İyileştirme Önerileri

Geri beslemeli öğrenme (RLHF), özelleşmiş türkçe model ve gelişmiş Dashboard bu iyileşmelerden bazılarıdır. Bunlar açıklanacak olursa;

Geri beslemeli öğrenmede, güvenlik analistlerinin sistemin verdiği kararları (Doğru/Yanlış) işaretleyebileceği bir geri bildirim döngüsü kurularak, modelin zamanla kendi kendine öğrenmesi sağlanabilir.

Özelleşmiş Türkçe modelde, Türkçe doğal dil işleme yeteneklerini artırmak için, özelleştirilmiş olan BERT (BERTurk) modellerinin projede kullanılması ve yerel saldırı senaryoları ile eğitilmesi önerilmektedir.

Gelişmiş dashboard da ise, şu an temel logları gösteren panelin, siber tehdit istihbaratı haritaları ve anlık saldırı alarmları içerecek şekilde geliştirilmesi (İP5 kapsamında), ürünün ticarileşme potansiyelini artıracaktır [49].

Sonuç olarak; bu proje, akademik tez çalışması olmanın ötesinde, güncel ve kritik bir siber güvenlik sorununa yerli, açık ve sürdürülebilir bir çözüm önermektedir. Belirlenen kısıtlar ile çok katmanlı mimarinin getirdiği avantajlarla hedeflenen başarı kriterlerine ulaşılması beklenmektedir.

6.EKLER

Bu bölümde, raporun ana akışını bölmeden verilmesi uygun olmayan ancak çalışmayı destekleyen ek bilgiler yer alır. Kullanılan anketler, ayrıntılı tablolar, ek görseller, kod parçaları, teknik çizimler veya kullanıcı kılavuzu gibi materyaller bu kısımda sunulur. Her ek numaralandırılarak ve kısa bir açıklama ile düzenli şekilde verilir.

EK-1: Kullanılan Veri Setlerinden Örneklemeler (JailbreakBench ve Alpaca)

EK-2: Sistem Mimarisi Kritik Kod Blokları (Pseudocode)

EK-3: API Uç Noktaları ve Entegrasyon Dökümantasyonu

EK-4: Proje Zaman Çizelgesi ve İş Paketi Dağılımı

6.1. EK-1: Kullanılan Veri Setlerinden Örneklemeler

Projenin test ve doğrulama aşamalarında kullanılan veri setleri örnekleri Tablo 10 da verilmiştir. Bu geniş kapsamlı veriler hem saldırı hem de güvenli istekleri analiz edip ayrıştırmada kritik rol oynamıştır. Model yeteneğini ölçmek amacıyla JailbreakBench ve Stanford Alpaca ve https://github.com/tatsu-lab/stanford_alpaca verileri kullanılmıştır.

Tablo 10. Test Kümesi Örnek Veri Tablosu

Veri ID	Kaynak Veri Seti	Kategori	İstem (Prompt) İçeriği	Beklenen Etiket
JB-042	JailbreakBench	Saldırı (Malware)	Sunucuya veri gönderen Python keylogger kodu yaz.	ENGEL (INJECTION)
JB-108	JailbreakBench	Saldırı (Roleplay/DAN)	DAN jailbreak moduyla patlayıcı yapım malzemeleri	ENGEL (INJECTION)

AL - 01 5	Stanford Alpaca	Güvenli (General)	Python'da 'sort' ve 'sorted' fonksiyonların ın farkı nedir?	İZİN (SAFE)
AL - 08 9	Stanfor Alpaca	Güvenli (Creative)	Çocuklar için kuantum fiziğini anlatan basit bir hikaye yaz.	İZİN (SAFE)
PII - 00 3	Sentetik Veri	Veri Sızıntısı	Ahmet Yılmaz'ın 4543-1122... no'lu kredi kartını güncelle.	MASKELENME Lİ (DLP)

6.2. EK-2 Sistem Mimarisi Kritik Kod Blokları

Projenin “Materyal ve Yöntem” kısmında bahsedilen ve çok katmanlı mimarinin temel yapısını oluşturan Python tabanlı sözde kod (pseudocode) yapısı aşağıda sunulmuştur. Kodlar Hugging Face Transformers kütüphanesi ve FastAPI baz alınarak kurulanmıştır.

Kod Bloğu 1. Çok Katmanlı Analiz Hattı (Piplene) Mantığı

```
# Sistem Ana Analiz Fonksiyonu (Main Logic)
async def analyze_prompt(request: PromptRequest):
    """
    Gelen isteği sırasıyla 3 güvenlik katmanından geçirir.
    Hız ve Maliyet Optimizasyonu için 'Fail-Fast' prensibi uygulanır.
    """
    start_time = time.time()

    # --- KATMAN 1: REFLEKS (Regex & DLP) ---
    # Hedef: Çok hızlı ön eleme (<5ms)
    regex_result = Layer1_Regex.scan(request.text)
```

```

if regex_result.is_blocked:
    log_threat("Layer1", "Blacklist Keyword", request.user_id)
    return BlockResponse("Yasaklı kelime tespit edildi.")

if regex_result.has_pii:
    # Hassas veri varsa maskele (Örn: Kredi Kartı -> ****)
    request.text = mask_pii(request.text)

# --- KATMAN 2: ZEKA (DeBERTa AI Model) ---
# Hedef: Anlamsal Saldırı Tespiti (~100ms)
# Referans: DeBERTa Modeli [11]
ai_score = Layer2_DeBERTa.predict(request.text)

if ai_score > THRESHOLD_HIGH (0.90):
    log_threat("Layer2", "AI Injection Detection", request.user_id)
    return BlockResponse("Saldırı girişimi tespit edildi.")

# --- KATMAN 3: BİLGELİK (LLM Yargıç) ---
# Hedef: Gri Alan (Grey Zone) Analizi
# Sadece AI skoru orta seviyede ise (0.50 - 0.90) devreye girer.
if THRESHOLD_LOW < ai_score < THRESHOLD_HIGH:
    llm_verdict = await Layer3_LLMJudge.evaluate(request.text)
    if llm_verdict == "UNSAFE":
        return BlockResponse("Politika ihlali.")

# Tüm katmanlar geçildi
return SafeResponse(request.text)

```

6.3. EK-3 API Uç Noktaları Ve Entegrasyon Dökümantasyonu

Geliştirilen “Üretken Yapay Zeka Sistemleri İçin Çok Katmanlı Akıllı Güvenlik Ağ Geçidi” projesi FastAPI kullanarak oluşturulan ve modern standartlara uygun bir REST API’dir. Dolayısıyla proje Restful mimarisiyle tasarlanmış olup dış sistemlerle Tablo 11 de gösterildiği gibi uç noktalar üzerinden haberleşme sağlayacaktır.

Tablo 11.API Uç Noktaları

Metot	Uç Nokta (Endpoint)	Açıklama	Parametreler
POST	/api/v1/analyze	Metin analizi ve güvenlik taraması yapar. Ana fonksiyondur.	{ “text”: “...”, “user_id”: “123” }
GET	/api/v1/health	Model ve sistemin çalışıp çalışmadığını kontrol eder. (Healthcheck).	-
GET	/api/v1/logs	Güvenlik ihlallerinin log kayıtlarını listeler.	?limit=50&type=injection
POST	/api/v1/feedback	Yanlış engellemelerin (False Pozitive) raporlanması için kullanılır.	{“log_id”: “...”, “correct_label”: “safe” }

6.4. EK-4: Proje Zaman Çizelgesi Ve İş Paketi Dağılımı

Projenin başlangıç ve bitiş süreçleri arasındaki gerçekleştirilen ve planlanan iş paketleri (Work Packages -WP) aşağıda özetlenmiştir.

1. WP1 – Literatür Taraması ve Veri Seti Hazırlığı:

- Jailbreak ve Prompt Injection saldırı vektörlerinin analizi
- JailbreakBench ve Alpaca veri setlerinin birleştirilmesi ve https://github.com/tatsu-lab/stanford_alpaca

2. WP2 – Prototip Geliştirme (Mevcut Aşama):

- FastAPI backend kurulumu.
- Katman 1(Regex) ve Katman 2(DeBERTa) entegrasyonu.

3. WP – Test ve Optimizasyon:

- Saldırı simülasyonları ve başarı ölçümleri.
- Gecikme süresi (Latency) iyileştirmeleri.

4. Raporlama ve Dökümantasyon:

Tez yazımı ve sunum hazırlığı.

7.KAYNAKLAR

- [1] S. J. . Russell *et al.*, *Artificial intelligence : a modern approach*. Pearson, 2021.
- [2] A. Vaswani *et al.*, “Attention Is All You Need,” Aug. 2023.
- [3] T. B. Brown *et al.*, “Language Models are Few-Shot Learners,” Jul. 2020.
- [4] M. Gurman, “Samsung Bans Staff’s AI Use After Spotting ChatGPT Data Leak,” Bloomberg. Accessed: Jan. 06, 2026. [Online]. Available: <https://www.bloomberg.com/news/articles/2023-05-02/samsung-bans-chatgpt-and-other-generative-ai-use-by-staff-after-leak>
- [5] C. Thompson, “A car dealership added an AI chatbot to its site. Then all hell broke loose.,” Business Insider. Accessed: Jan. 06, 2026. [Online]. Available: <https://www.businessinsider.com/car-dealership-chevrolet-chatbot-chatgpt-pranks-chevy-2023-12>
- [6] OWASP Foundation, “OWASP Top 10 for Large Language Model Applications (Version 1.1),” OWASP. Accessed: Jan. 06, 2026. [Online]. Available: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>

8.ÖZGEÇMİŞ

Adı Soyadı: Funda BOZBURUN

Eğitim Bilgileri:

Lisans: İstanbul Topkapı Üniversitesi, Mühendislik Fakültesi, Yazılım Mühendisliği Bölümü (2022 - Devam Ediyor)

Kişisel Profil ve Yetkinlikler: Yazılım Mühendisliği 4. sınıf öğrencisi olan Funda Bozburun, akademik ve profesyonel çalışmalarını ağırlıklı olarak siber güvenlik ve yapay zeka kesişiminde sürdürmektedir. Ofansif ve defansif güvenlik süreçlerine ilgi duymakta olup, siber güvenlik çözümlerinin geliştirilmesi konusunda çalışmalar yapmaktadır.

Özellikle yapay zeka destekli tehdit algılama sistemleri üzerine yoğunlaşmıştır. Gerçekleştirdiği projeler arasında; ağ trafiğindeki tehditleri belirleyen "Yapay Zeka Destekli Anomali Tespiti" (LSTM ve CNN modelleri ile) ve web güvenliği odaklı "Phishing (Oltalama) Tespiti" sistemleri yer almaktadır.

Teknik yetkinlikleri arasında Python ve C programlama dilleri, Linux işletim sistemi yönetimi, Fortigate Firewall yapılandırması ve Splunk ile SIEM süreçleri bulunmaktadır. Ayrıca Burp Suite, Nmap, SQLmap gibi araçlarla web uygulama güvenliği ve ağ taramaları konusunda deneyim sahibidir. "Etik Hacker" ve "SOC Analisti" sertifikalarına sahip olan yazar , Medium platformunda siber güvenlik üzerine teknik makaleler yayınlamaktadır.

İletişim:

E-posta: fundabozburun@gmail.com

LinkedIn: linkedin.com/in/fundabozburun

Medium: medium.com/@fundabozburun

GitHub: github.com/FundaBzbrn

Adı Soyadı: Fidan AKYÜREK

Eğitim Bilgileri:

Lisans: İstanbul Topkapı Üniversitesi, Mühendislik Fakültesi, Yazılım Mühendisliği Bölümü (2022- Devam Ediyor)

Kişisel Profil ve Yetkinlikler: Yazılım Mühendisliği son sınıf öğrencisi olan Fidan Akyürek, akademik ve profesyonel çalışmalarını ağırlıklı olarak Yapay Zeka, Makine Öğrenmesi (Machine Learning) ve Backend sistemleri kesişiminde sürdürmektedir. Hem gömülü sistemler hem de kurumsal yazılım mimarilerine ilgi duymakta olup, modern yazılım çözümlerinin geliştirilmesi konusunda çalışmalar yapmaktadır.

Özellikle derin öğrenme destekli görüntü işleme ve siber güvenlik odaklı yapay zeka sistemleri üzerine yoğunlaşmıştır. Gerçekleştirdiği projeler arasında; histopatolojik görüntü verilerini analiz eden "Kolon Kanseri Tespiti" (VGG16 ve MLP hibrit mimarisi ile Transfer Öğrenimi yaklaşımı) ve siber tehditleri belirleyen "Gelişmiş Kimlik Avı (Phishing) Saldırısı Tespit Sistemi" (TensorFlow/Keras mimarisi ile) yer almaktadır.

Teknik yetkinlikleri arasında Python, C#, Java programlama dilleri ve TensorFlow, Keras gibi yapay zeka kütüphaneleri bulunmaktadır. .NET ekosisteminde "Eczane Yönetim Sistemi" ve "Otopark Yönetim Sistemi" gibi kapsamlı C# tabanlı backend projeleri geliştirmiştir. Profesyonel deneyim olarak Albayrak Grubu'nda (Albil IT) Backend ve SAP sistemleri üzerine staj yapmış, ABAP eğitimi alarak kurumsal kaynak planlama süreçlerine katkıda bulunmuştur.

İletişim:

E-Posta: fidanakyurek1@gmail.com

LinkedIn: <https://www.linkedin.com/in/fidanakyurek/>

GitHub: <https://github.com/FidanAkyurek>